

TBox 安全服务产品说明书

基于 OP-TEE 可信执行环境的密钥管理与密码学运算系统

版本: v1.0 | 日期: 2026-07-22

适用范围: 基于 ARM TrustZone 的 TBox 车联网终端

目录

第一章：产品概述

- 1.1 产品定义
- 1.2 核心价值
- 1.3 产品组件全景图

第二章：安全架构

- 2.1 可信执行环境
- 2.2 密钥存储加密链
- 2.3 密钥操作调用路径
- 2.4 安全启动信任链
- 2.5 安全边界总结

第三章：应用场景

- 3.1 场景总览
- 3.2 HTTPS 双向认证
- 3.3 MQTTS 双向认证
- 3.4 多业务密钥管理

第四章：产线灌装

- 4.1 灌装流程
- 4.2 证书签发
- 4.3 安全约束

第五章：开发集成

- 5.1 ENGINE SDK

5.2 HTTPS 集成

5.3 MQTTS 集成

第六章：运维与恢复

6.1 密钥生命周期

6.2 误操作恢复

6.3 故障排查

第七章：安全与合规

7.1 威胁模型

7.2 法规对齐

附录：技术指标与术语

第一章：产品概述

1.1 产品定义

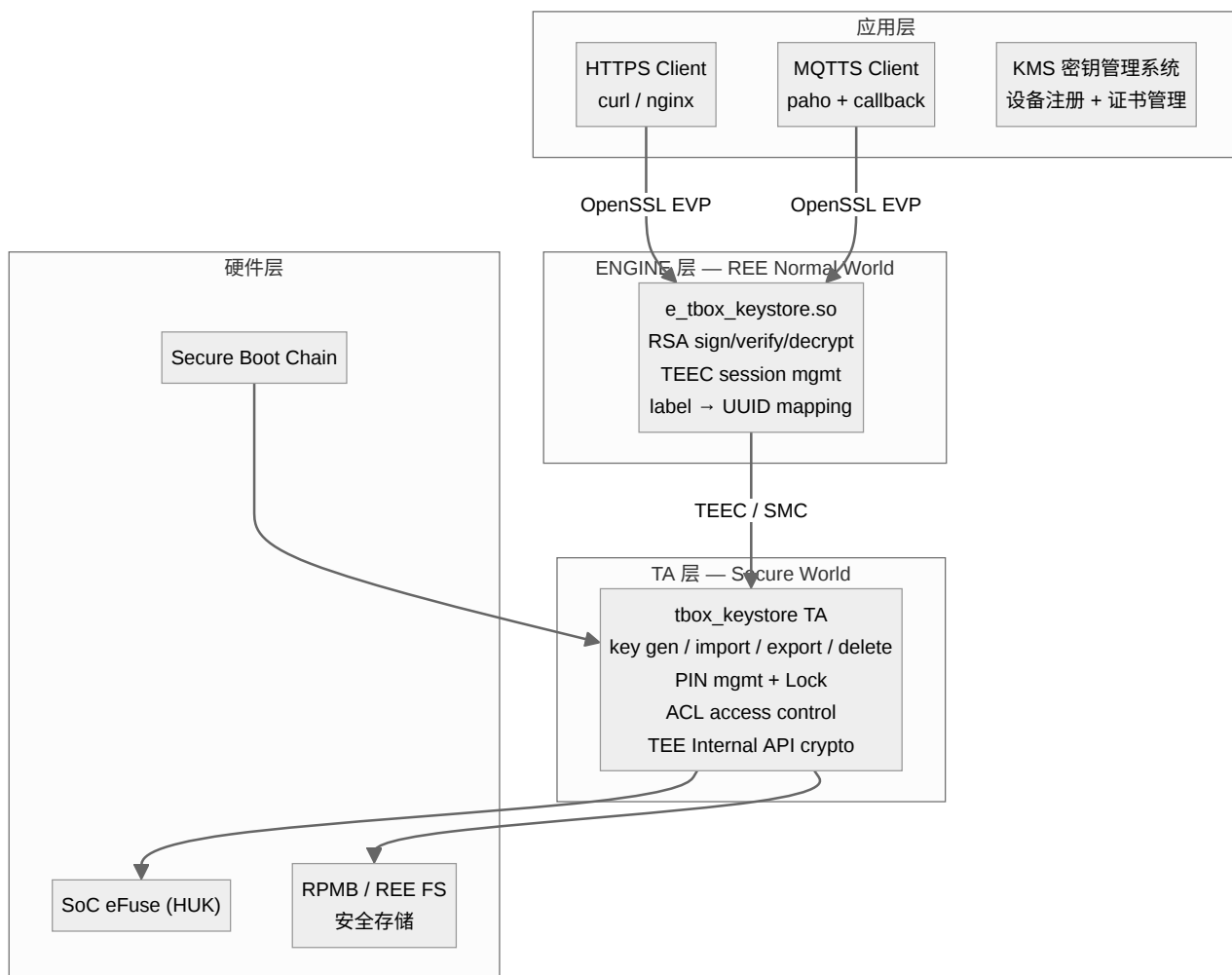
TBox 安全服务在车载终端 SoC 的 ARM TrustZone 安全区域中运行，利用 OP-TEE 操作系统和自研密钥管理 TA（Trusted Application），为设备提供以下核心安全能力：

- **密钥生成与存储：**在安全区域内部生成 RSA/AES/SM2 等密钥，私钥永不出安全域
- **密码学运算：**RSA 签名/验签、AES 加解密、RSA PKCS#1 解密等操作在 TEE 内完成
- **TLS 双向认证：**通过 OpenSSL ENGINE 标准接口将密码学操作接入 HTTPS 和 MQTTs 协议栈
- **产线一机一密：**每台设备在工厂灌装唯一密钥，配合 CA 证书体系实现设备身份认证

1.2 核心价值

价值	说明
密钥不出安全域	私钥在 TEE 内生成、使用、销毁全生命周期不离开 ARM TrustZone
标准协议兼容	通过 OpenSSL ENGINE API 无缝接入，应用层代码无需修改
一机一密	每台设备唯一密钥，设备身份可认证、可追踪、可吊销
硬件信任根	基于 SoC eFuse 中 HUK（硬件唯一密钥）的加密链，绑定芯片不可迁移
车规级合规	架构对齐 ISO 21434 / WP.29 UN R155，支持国密算法扩展

1.3 产品组件全景图



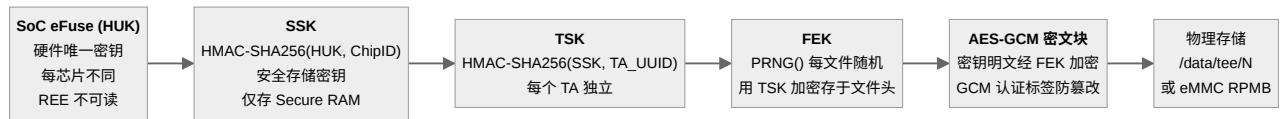
第二章：安全架构

2.1 可信执行环境

TBox 安全服务构建在 ARM TrustZone 技术之上，将 SoC 分为两个世界：

	普通世界 (REE)	安全世界 (TEE)
操作系统	Linux	OP-TEE OS
CPU 模式	Non-Secure	Secure (S-EL1)
内存访问	仅 REE 内存	REE 内存 + Secure RAM
密钥可见性	仅公钥、label 字符串	全部密钥材料

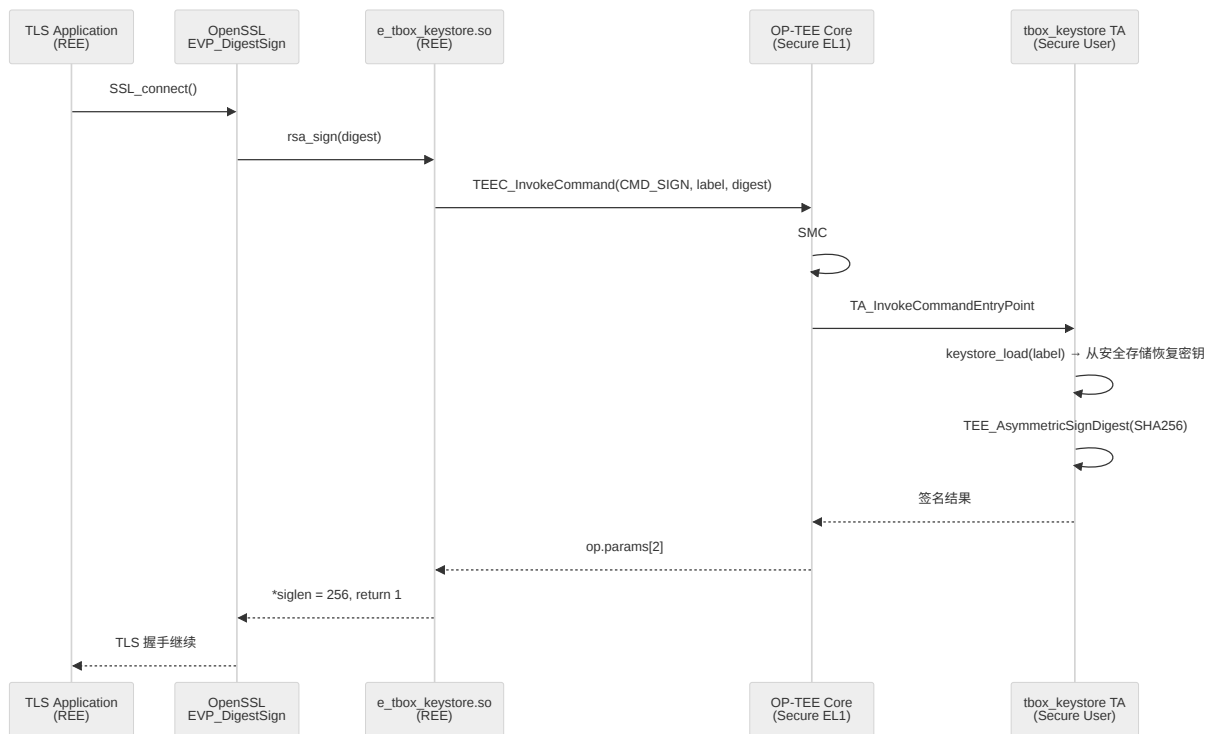
2.2 密钥存储加密链



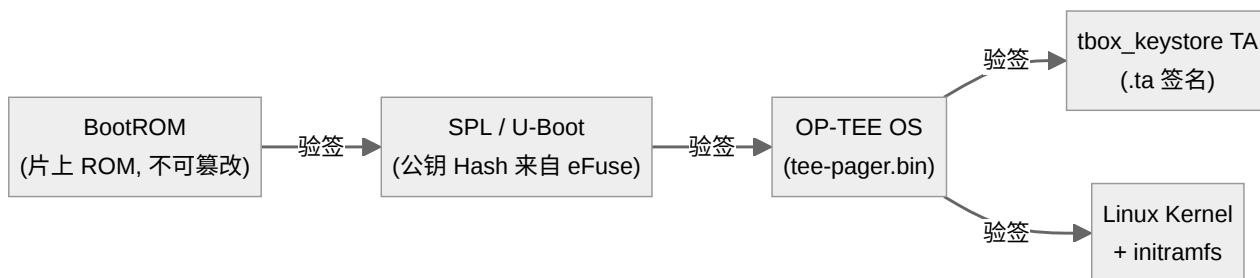
即使攻击者 dump 了 REE 侧全部文件系统，得到的也只是 AES-GCM 密文块。没有 HUK 无法派生出任何解密密钥。

2.3 密钥操作调用路径

以 TLS 握手 CertificateVerify 签名为例：



2.4 安全启动信任链



每级镜像的签名由上一级验证，信任锚固定在 SoC eFuse 中，形成不可绕过的信任链。

2.5 安全边界总结

攻击面	防护	等级
REE 直接读安全存储文件	AES-GCM 加密，密钥在 TEE 内	✅ 机密性
REE 篡改安全存储文件	GCM 认证标签校验	✅ 完整性
物理 dump eMMC	密钥链绑定 SoC HUK	✅ 硬件绑定
替换 TA 二进制	TA 签名验签	✅ 防篡改
回滚旧密钥文件	RPMB 硬件写计数器	✅ 防回滚

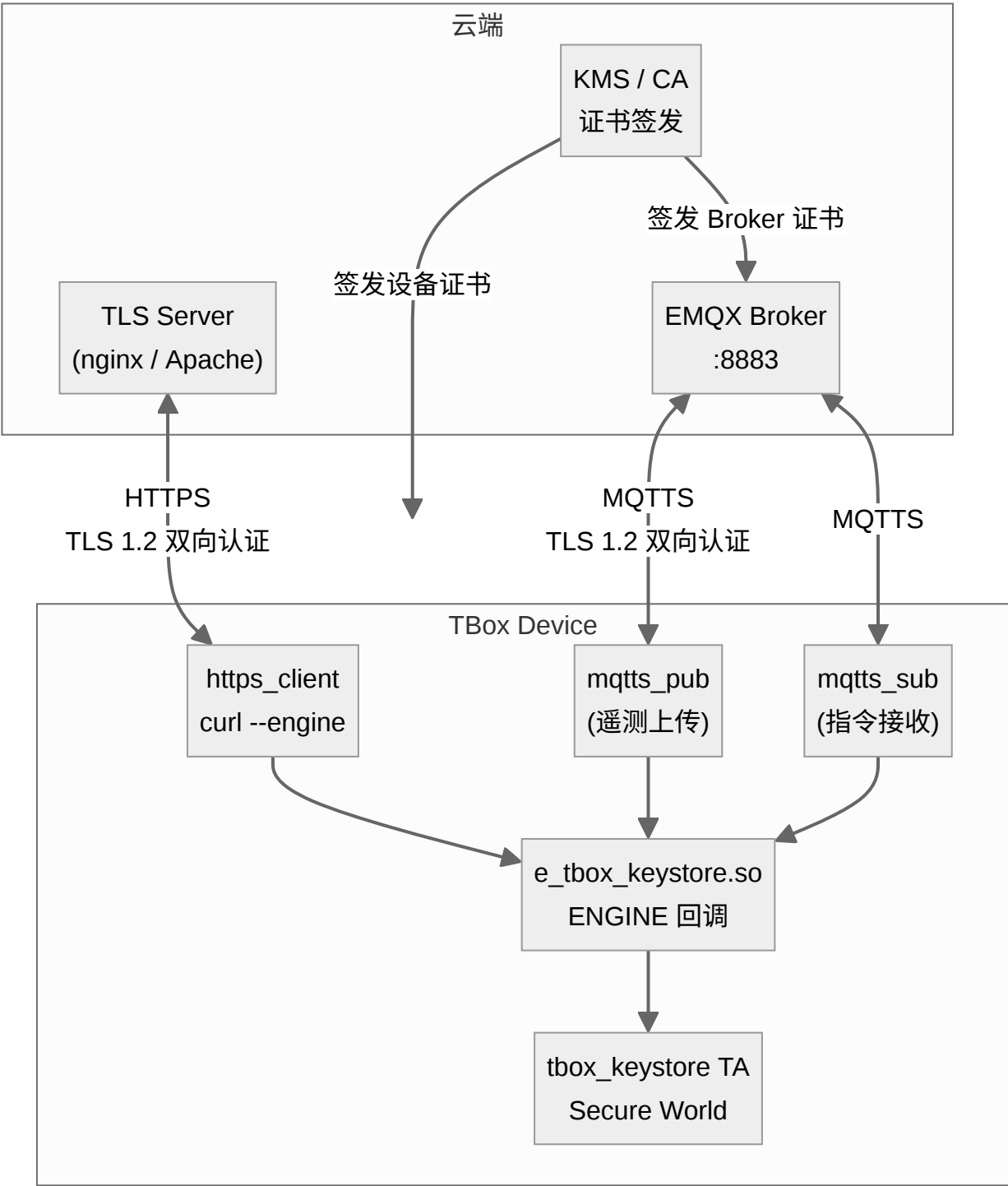
恶意应用调用 TA

PIN + Lock 访问控制

☒ 访问控制

第三章：应用场景

3.1 场景总览



3.2 HTTPS 双向认证

应用层使用标准 OpenSSL API，只需在 SSL_CTX 初始化时通过 ENGINE 加载 TA 私钥：


```
ENGINE_load_tbox_keystore();
ENGINE *e = ENGINE_by_id("tbox_keystore");
EVP_PKEY *pkey = ENGINE_load_private_key(e, "tls-key", NULL, NULL);
SSL_CTX_use_PrivateKey(ctx, pkey);
// 后续 TLS 握手自动使用 TEE 密钥
```

已通过 `https_client` 程序完成端到端验证：ENGINE 加载 TA 密钥 → TLS 握手 → HTTPS GET → HTTP 200 OK。

3.3 MQTTS 双向认证

paho.mqtt.c 库通过最小补丁（`SSLSocket_setExternalConfigCallback`）支持外部 SSL 配置注入。当 `privateKey = "__EXTERNAL_CONFIG__"` 时，paho 在创建 `SSL_CTX` 后自动调用回调完成 ENGINE 凭据加载。

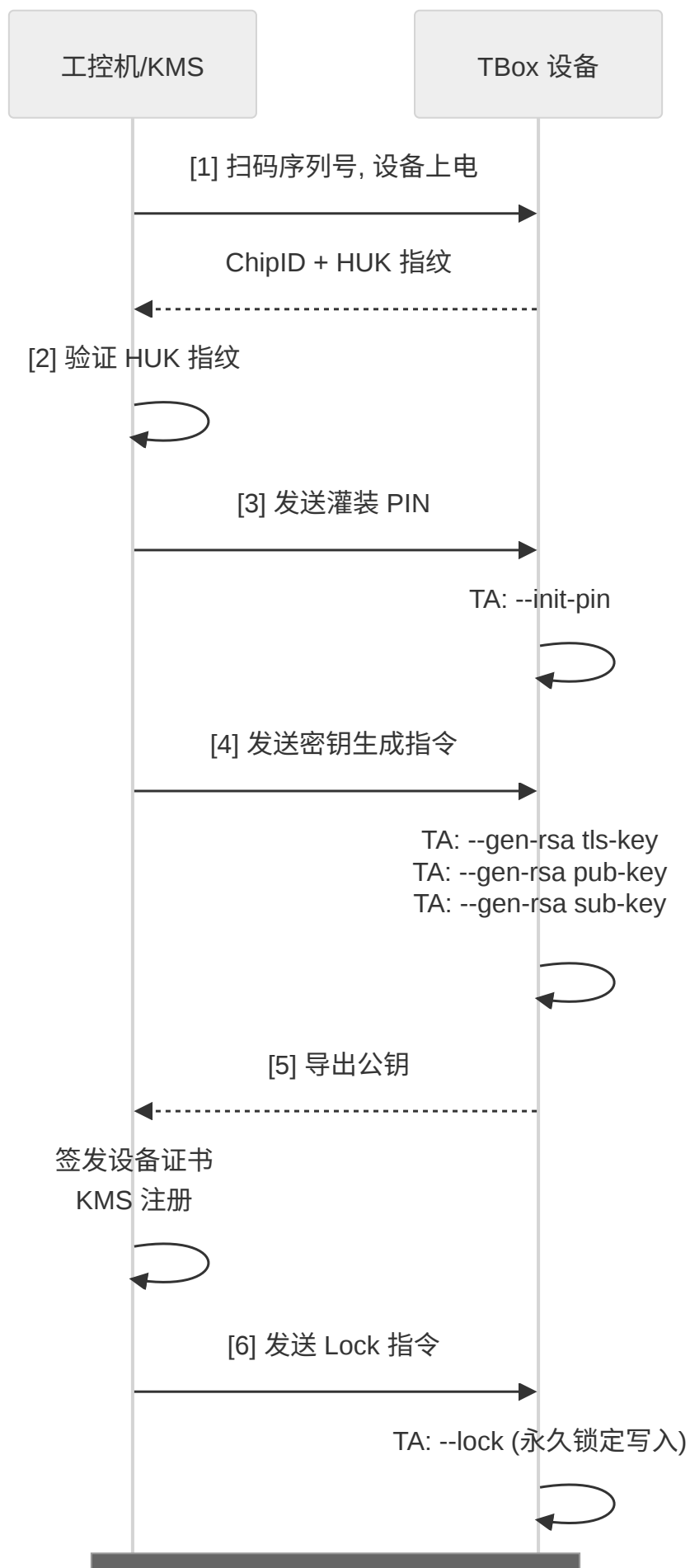
```
SSLSocket_setExternalConfigCallback(tbox_ssl_config_pub);
MQTTClient_create(&client, "ssl://broker:8883", "tbox-device", ...);
ssl_opts.privateKey = "__EXTERNAL_CONFIG__";
MQTTClient_connect(client, &conn_opts);
// TLS 握手签名走 ENGINE → TA
```

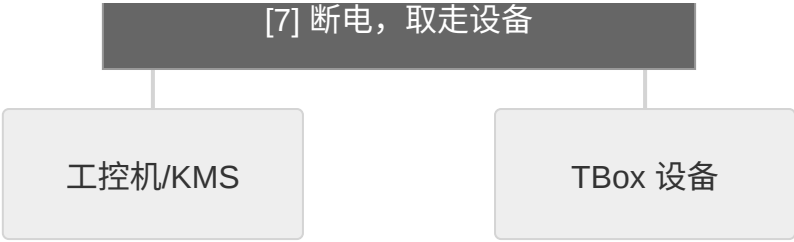
3.4 多业务密钥管理

业务	Key Label	证书	用途
TLS 服务	tls-key	tls.crt	HTTPS 双向认证
OTA 升级	ota-key	ota.crt	OTA 包签名
日志加密	log-key	—	AES 对称加密
MQTT 发布	pub-key	pub.crt	遥测数据上传
MQTT 订阅	sub-key	sub.crt	远程指令接收

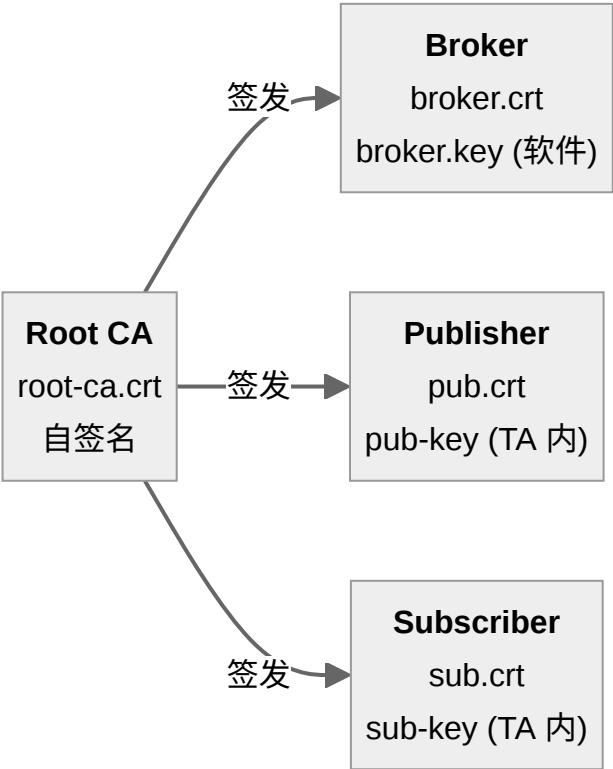
第四章：产线灌装

4.1 灌装流程





4.2 证书签发



4.3 安全约束

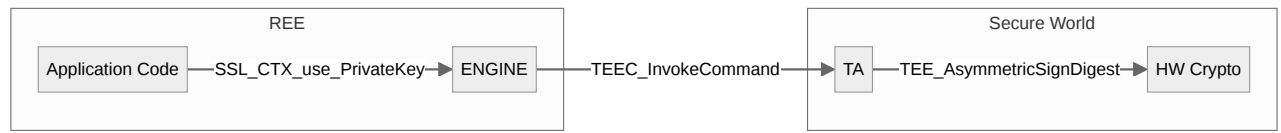
约束	措施
物理安全	工厂车间门禁 + 摄像头监控
网络安全	工控机与设备直连 USB/专用 VLAN，不接入公网
PIN 管理	灌装 PIN 由 KMS 生成，灌装完成后立即废弃
Lock 机制	灌装完成后 TA 永久锁定，禁止新增/删除密钥
审计日志	每台设备记录时间戳、操作员、序列号、公钥指纹

第五章：开发集成

5.1 ENGINE SDK

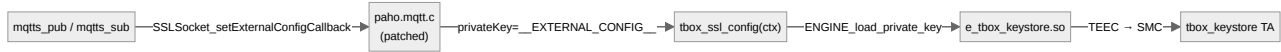
组件	文件	用途
ENGINE 共享库	libe_tbox_keystore.so	链接到应用进程，注册 OpenSSL ENGINE
TA 二进制	f8e9209a-*.ta	部署到 /lib/optee_armtz/，Secure World 运行
公开头文件	tbox_keystore_ta.h	UUID、命令 ID 定义
CA 工具	tbox_keystore CLI	命令行密钥管理（灌装、查询、签名）

5.2 HTTPS 集成



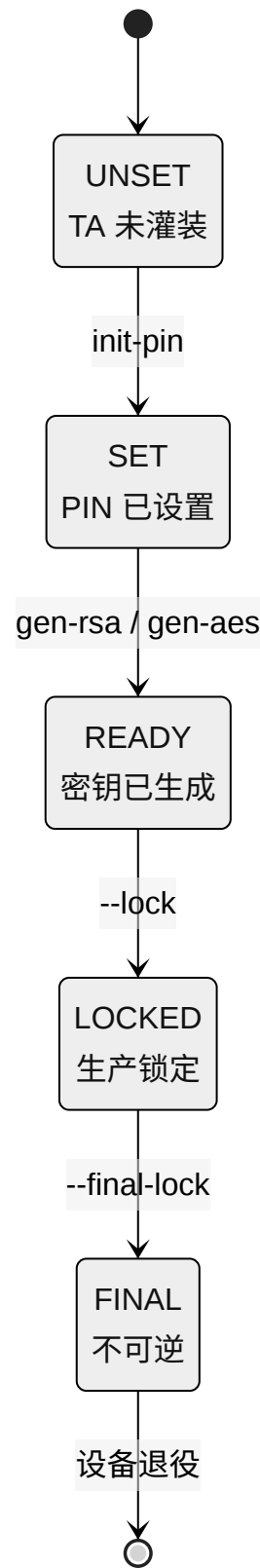
应用层使用标准 OpenSSL API，无需修改业务逻辑。TLS 握手时私钥操作自动路由到 TA。

5.3 MQTTS 集成



第六章：运维与恢复

6.1 密钥生命周期



状态	生成密钥	删除密钥	签名/验签	加解密
UNSET	✗	✗	✗	✗
SET / READY	✓	✓	✓	✓
LOCKED / FINAL	✗	✗	✓	✓

6.2 误操作恢复

级别	手段	授权方式	适用场景
Lv0	改 UUID 重新编译 TA / 擦除 REE FS	无（仅开发板）	开发调试
Lv1	工控机签名 unlock 命令（N 小时窗口）	工控机 HSM	产线误操作
Lv2	SO PIN 验证后解锁	管理员 PIN	出厂后未 final-lock
Lv3	设备退回工厂，HSM 签名恢复镜像	物理接触 + HSM	RMA 返厂
Lv4	不可恢复（final-lock 后彻底锁定）	无	最高安全需求

6.3 故障排查

现象	检查点
ENGINE init 失败	<code>ls /lib/optee_armtz/*.ta</code> 确认 TA 已部署
Key not found	<code>tbox_keystore --info <label></code> 确认密钥已灌装
TLS 握手失败	检查证书是否由同一 Root CA 签发，时钟是否同步
MQTT CONNECT 失败	先测 TCP (<code>telnet broker port</code>), 再查证书验证
跨进程冲突	每进程只访问自己的 key label，避免并发操作同一持久化对象

第七章：安全与合规

7.1 威胁模型

威胁	攻击面	防护
提取私钥	REE 内存 dump	私钥仅在 TEE Secure RAM，REE 不可见
替换密钥	篡改安全存储文件	AES-GCM 完整性校验
重放攻击	回滚旧密钥文件	RPMB 硬件写计数器
伪造设备	克隆设备证书	HUK 硬件绑定，换芯片失效
供应链攻击	替换 TA 二进制	Secure Boot 验签链
侧信道攻击	时序/功耗分析	HW Crypto Cell 常数时间运算

7.2 法规对齐

法规	要求	实现
ISO 21434	道路车辆网络安全	TARA 威胁分析 + 安全启动 + 密钥管理审计
WP.29 UN R155	车辆网络安全认证	OTA 安全更新 + 事件响应
GDPR	个人数据保护	密钥销毁证明 + 设备退役流程
国密 GM/T	商用密码	架构支持 SM2/SM3/SM4 扩展

附录：技术指标与术语

A.1 技术指标

指标	值
RSA-2048 签名延迟	< 50 ms（TEE 内运算）
RSA-2048 密钥存储	~3 KB / 个
最大密钥数量	受安全存储分区大小限制（典型 ~100 个）
OpenSSL 版本	1.1.1w
paho.mqtt.c 版本	1.3.16（带补丁）
安全存储后端	REE FS（开发）/ RPMB（量产）
并发模型	每进程独立 TEEC session + session 级密钥缓存

A.2 术语表

术语	说明
TEE	Trusted Execution Environment, 可信执行环境
REE	Rich Execution Environment, 普通执行环境（Linux）
TA	Trusted Application, 运行在 TEE 中的应用程序
CA	Client Application, 运行在 REE 中调用 TA 的程序
HUK	Hardware Unique Key, SoC eFuse 中的硬件唯一密钥
SSK	Secure Storage Key, 由 HUK 派生的安全存储密钥
TSK	TA Storage Key, 每个 TA 独立的存储密钥
FEK	File Encryption Key, 每个持久化文件一个的加密密钥
ENGINE	OpenSSL 的扩展机制, 用于将密码学操作外挂到外部硬件
RPMB	Replay Protected Memory Block, eMMC 防回滚安全分区
KMS	Key Management System, 密钥管理系统

A.3 相关技术文档

- [01-architecture-overview.md](#) — 五种方案对比与选型
- [05-key-storage.md](#) — 密钥 TEE 内存储机制详解
- [07-provisioning-procedure.md](#) — 产线灌装详细流程

- [13-openssl-engine-integration.md](#) — ENGINE 集成完整方案
- [14-brick-recovery-and-best-practices.md](#) — 变砖场景与救砖方案
- [15-engine-debug-issues.md](#) — ENGINE 调试 15 个问题全记录
- [16-multi-process-concurrency-analysis.md](#) — 多进程并发分析
- [18-mqtt-mutual-auth-demo.md](#) — MQTT 双向认证方案
- [20-mqtts-debug-issues.md](#) — MQTTS 调试 7 个问题全记录